

API Dependabot Design Document

AI Engineering Capstone | 28 September 2026

Problem statement

Java and Spring Boot teams that consume third-party APIs need to determine whether a new API contract affects their client code, where that code lives, and what to review before upgrading. API Dependabot compares two OpenAPI 3.x specifications, searches a Java/Maven consumer repository for supporting evidence, and produces an evidence-cited migration assessment.

The capstone prototype is limited to OpenAPI 3.x, Java/Spring Boot, Maven, and GitHub repositories. It is an advisory command-line tool. It does not autonomously edit code, run consumer tests in Docker, open a pull request, or deploy a service.

Architecture

A deterministic OpenAPI parser and diff establish contract facts. A repository adapter accepts a local checkout or shallow GitHub clone. Java source and test search returns file and line evidence, while a lexical retriever ranks bounded code, test, build, README, and diff chunks. ReAct tools can inspect the diff, search Java, read bounded Java ranges, and retrieve evidence.

Stage	Implementation
Contract analysis	Parse old and new OpenAPI documents; report changes and review notes.
Repository surface	Search Java source/tests in a local checkout or shallow GitHub snapshot.
Retrieval	Rank 25-line evidence chunks with 5-line overlap and retain source locations.
Vanilla RAG	Retrieve once, then make a single evidence-grounded model request.
ReAct	Use a read-only tool loop for diff inspection, Java search/read, and retrieval; maximum eight calls.

Comparison

Promptfoo runs both approaches on the same six labeled development cases with the same deterministic symbol assertion and LLM-as-a-judge rubric. The latest rerun passed 6/6 for each approach. The first run exposed an unsupported ReAct claim; a grounding instruction was revised and the case passed on rerun. These cases are not held out and do not settle the architecture choice.

Evaluation criteria

Measure	Purpose
Pass rate and judge score	Compare whether answers address the expected migration assessment and remain grounded.
Evidence support	Check whether repository-specific claims cite actual tool evidence and paths.
Latency	Measure answer time for practical use.
Tool calls	Quantify ReAct orchestration effort.
Human review	Review correctness, clarity, uncertainty, and unsupported claims; expand for held-out runs.

Framework justification

Java 21, Spring Boot, and Maven match the target consumer ecosystem and developer background. Spring AI supplies model and tool-calling integration while keeping deterministic diff and retrieval components independently inspectable. OpenAPI parser/diff tooling avoids hand-written specification parsing, with curated fixtures guarding library behavior. Promptfoo provides paired evaluation. A vector database, PostgreSQL, and multi-agent orchestration were not added because the current scope does not justify their complexity.

Boundaries and next validation

- Lexical Java search may miss generated, reflective, indirect, or non-Java call paths.
- A model, service, or test mentioning a field does not prove it sends an affected API request.
- The LLM judge is not ground truth; six development cases and one rerun are not a held-out study.
- GitHub support reads a shallow snapshot; no PR creation, isolated consumer test execution, hosted HTTP API, or deployment is implemented.

Next evaluation: add held-out cases, compare on identical inputs, and manually review a sample before selecting an architecture.